



Gouvernance et gestion des risques de la sécurité de l'information

Diapositives complètes — Dr. Zakaria Sawadogo, École Polytechnique de Ouagadougou

Chapitre 1 — Introduction à la gouvernance de la sécurité de l'information

Gouvernance et gestion des risques SI

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Définition de la gouvernance SSI

La **gouvernance de la sécurité de l'information** (souvent abrégée SSI, ou GSI) désigne l'ensemble des structures organisationnelles, des processus formalisés et des mécanismes de décision qui permettent à une organisation de définir, de piloter et de faire évoluer sa stratégie de sécurité, en cohérence avec ses objectifs métiers, ses obligations légales et son appétence au risque. Elle ne se réduit ni à un ensemble d'outils techniques, ni à une fonction isolée : c'est un système de management à part entière, au même titre que la gouvernance financière ou la gouvernance qualité, qui traverse l'ensemble de l'organisation, de la direction générale jusqu'aux équipes opérationnelles.

Il est essentiel de distinguer la gouvernance de la **sécurité opérationnelle**, c'est-à-dire la mise en œuvre technique quotidienne (configuration de pare-feu, application de correctifs, surveillance des journaux). Les deux niveaux sont complémentaires mais répondent à des questions différentes :

- La **gouvernance** définit le « quoi » et le « pourquoi » : quels risques l'organisation accepte-t-elle de courir, quelles ressources alloue-t-elle à la sécurité, quelles priorités stratégiques retient-elle, qui est responsable de quoi ?
- Le niveau **opérationnel** exécute le « comment » : il traduit les orientations de gouvernance en mesures techniques et organisationnelles concrètes, au jour le jour.

Une analogie utile : la gouvernance SSI joue, pour la sécurité de l'information, un rôle comparable à celui du conseil d'administration et de la direction financière pour la gestion budgétaire d'une entreprise — elle fixe le cap, arbitre les priorités et rend des comptes, sans pour autant configurer elle-même les équipements. Sans cette couche de gouvernance, une organisation peut disposer d'excellentes compétences techniques individuelles tout en restant globalement vulnérable, faute de cohérence d'ensemble, de priorisation claire et de portage par la hiérarchie.

2. Pourquoi la sécurité doit être gouvernée et non seulement « techniquement gérée »

Plusieurs raisons structurelles expliquent pourquoi la sécurité de l'information ne peut pas rester une préoccupation purement technique, confinée aux équipes informatiques :

La sécurité a un coût et engage des arbitrages qui dépassent le périmètre technique. Investir dans la sécurité signifie mobiliser un budget, des ressources humaines qualifiées (souvent rares et coûteuses) et du temps, autant d'éléments qui entrent en concurrence avec d'autres priorités de l'organisation (développement de nouveaux produits, expansion commerciale, autres projets informatiques). Ces arbitrages relèvent par nature de décisions de direction : un responsable technique ne peut pas, seul, décider du niveau de risque que l'organisation est prête à assumer, ni du montant qu'elle est prête à investir pour le réduire.

Les conséquences d'un incident de sécurité majeur dépassent largement le périmètre informatique. Une compromission de données, une interruption prolongée de service ou une fraude numérique peuvent entraîner des conséquences juridiques (mise en cause de la responsabilité de l'organisation, sanctions réglementaires), financières (coûts de remédiation, pertes d'exploitation, primes d'assurance) et réputationnelles (perte de confiance des clients, des partenaires, des investisseurs). Ces impacts touchent directement la mission et la pérennité de l'organisation, ce qui justifie que la direction générale soit impliquée dans la définition de l'appétence au risque acceptée, et non seulement informée après coup.

Sans portage par la direction, les recommandations issues des audits restent rarement suivies d'effet. Un audit de sécurité (organisationnel ou technique, comme évoqué dans le module précédent) produit généralement une liste de constats et de recommandations. Si ces recommandations ne sont pas reprises, arbitrées et suivies par une instance de gouvernance disposant d'une autorité réelle, elles ont tendance à rester lettre morte : les équipes opérationnelles, en tension permanente entre plusieurs priorités concurrentes, n'ont ni le mandat ni les ressources pour les mettre en œuvre de leur propre initiative. La gouvernance transforme ainsi des constats d'audit isolés en un plan d'action suivi et budgété.

En synthèse, la gouvernance SSI est ce qui permet de faire de la sécurité une préoccupation continue et pilotée, plutôt qu'une succession de réactions ponctuelles à des événements ou à des injonctions réglementaires.

3. Les rôles clés

Une gouvernance SSI efficace repose sur une répartition claire des rôles et responsabilités entre plusieurs parties prenantes, dont les intérêts ne sont pas toujours spontanément alignés :

Rôle	Responsabilité principale
Direction générale	définit l'appétence au risque de l'organisation, arbitre les budgets alloués à la sécurité, porte et incarne la culture sécurité auprès de l'ensemble du personnel
RSSI (Responsable de la Sécurité des Systèmes d'Information)	pilote la stratégie SSI, anime les instances de gouvernance (comités, revues), coordonne la gestion des risques et rapporte régulièrement à la direction sur l'état de la sécurité
DSI (Direction des Systèmes d'Information)	met en œuvre les moyens techniques nécessaires au fonctionnement du système d'information, souvent en tension avec le RSSI sur l'arbitrage entre disponibilité/performance et exigences de sécurité
Propriétaires de processus métier (<i>business owners</i>)	identifient la valeur et la criticité des actifs qu'ils exploitent au quotidien, et arbitrent, sur leur périmètre, le traitement du risque en connaissance des enjeux métier
Correspondants sécurité / DPO (Délégué à la Protection des Données)	jouent le rôle de relais opérationnels de la politique de sécurité dans les entités, et assurent le suivi de la conformité réglementaire, notamment en matière de protection des données personnelles

Chacun de ces rôles apporte un éclairage différent et souvent complémentaire : la direction porte la vision stratégique et l'autorité de décision, le RSSI apporte l'expertise sécurité et la vision transverse des risques, la DSI connaît les contraintes techniques réelles, et les propriétaires métier connaissent la valeur business des actifs qu'ils gèrent. C'est précisément la confrontation organisée de ces points de vue, au sein d'instances de gouvernance formalisées, qui permet des décisions équilibrées plutôt que des décisions prises isolément par un seul acteur.

Un point de vigilance de gouvernance fréquemment souligné dans la littérature et les référentiels professionnels concerne le **positionnement organisationnel du RSSI** : pour préserver son indépendance et sa capacité à challenger les choix techniques (par exemple, alerter sur un risque introduit par un projet porté par la DSI), le RSSI ne devrait idéalement pas être rattaché hiérarchiquement à la DSI. Un rattachement direct à la direction générale, à la direction des risques, ou à une fonction équivalente, est généralement recommandé pour éviter les conflits d'intérêts entre impératifs de disponibilité/performance des systèmes et impératifs de sécurité.

4. Les composantes d'un système de gouvernance SSI

Un système de gouvernance SSI complet s'articule généralement autour de cinq composantes qui s'enchaînent de façon cohérente, du cadrage stratégique jusqu'au pilotage opérationnel :

1. **Politique de sécurité (PSSI)** : document de référence formalisant les orientations stratégiques, les principes directeurs et les responsabilités en matière de sécurité de l'information. C'est le socle documentaire sur lequel s'appuient toutes les décisions ultérieures ; ce sujet sera approfondi au chapitre 3.
2. **Organisation** : mise en place de comités de pilotage (par exemple un comité sécurité réunissant régulièrement direction, RSSI et représentants métier), d'instances de décision clairement identifiées, et de circuits d'escalade permettant de faire remonter rapidement une décision urgente au bon niveau hiérarchique.
3. **Gestion des risques** : méthodologie structurée d'identification, d'évaluation et de traitement des risques pesant sur les actifs informationnels de l'organisation. Ce processus, central dans toute démarche de gouvernance, fait l'objet d'un développement complet au chapitre 2.
4. **Conformité** : suivi systématique des obligations légales, réglementaires et contractuelles applicables à l'organisation (protection des données personnelles, réglementations sectorielles, exigences contractuelles imposées par des clients ou partenaires).
5. **Pilotage et amélioration continue** : mise en place d'indicateurs et de tableaux de bord permettant de mesurer l'efficacité du dispositif de sécurité dans la durée, complétée par des audits internes réguliers et des revues de direction périodiques, qui referment la boucle et alimentent le cycle suivant.

Ces cinq composantes ne fonctionnent pas de façon isolée : la politique de sécurité fixe le cap, la gestion des risques identifie ce qui doit être traité en priorité, la conformité impose un plancher réglementaire incompressible, et le pilotage vérifie que l'ensemble produit des résultats mesurables, ce qui, en retour, alimente la révision de la politique et des priorités.

5. Cadres de référence en gouvernance SSI

Plusieurs référentiels internationaux structurent aujourd'hui la pratique de la gouvernance SSI. Ils ne sont pas concurrents mais souvent complémentaires, chacun apportant un éclairage ou un niveau de détail différent :

- **ISO/IEC 27001** : norme internationale de certification qui définit les exigences d'un Système de Management de la Sécurité de l'Information (SMSI). Elle met un accent particulièrement fort sur le pilotage par la direction, notamment à travers sa clause 5 (« Leadership »), qui exige un engagement démontrable de la direction générale, et non une simple délégation formelle à une équipe technique.
- **COBIT** (*Control Objectives for Information and Related Technologies*), maintenu par l'ISACA, est un cadre de gouvernance des systèmes d'information au sens large, qui englobe la sécurité parmi un ensemble plus vaste d'objectifs de gouvernance et de gestion des technologies de l'information (performance, valeur, conformité, gestion des risques).
- **NIST Cybersecurity Framework** (CSF), publié par l'institut américain de normalisation NIST, structure la gouvernance et la gestion opérationnelle de la cybersécurité autour de fonctions clés — historiquement au nombre de cinq (*Identify, Protect, Detect, Respond, Recover*), auxquelles la fonction *Govern* a été ajoutée dans les versions les plus récentes du cadre pour souligner explicitement le rôle central de la gouvernance. Ce cadre, bien qu'initialement conçu pour un contexte américain, est aujourd'hui largement adopté à l'international du fait de sa lisibilité et de sa flexibilité.

Le tableau suivant synthétise les usages typiques de ces trois référentiels :

Référentiel	Nature	Usage typique
ISO/IEC 27001	Norme certifiable	Démontrer formellement, via un audit tierce partie, la mise en place d'un SMSI conforme
COBIT	Cadre de gouvernance IT global	Aligner la gouvernance SSI sur la gouvernance IT et la création de valeur pour l'organisation
NIST CSF	Cadre volontaire, non certifiable	Structurer l'auto-évaluation et la communication sur la maturité cybersécurité

En pratique, une organisation peut très bien s'appuyer simultanément sur plusieurs de ces référentiels : par exemple, viser une certification ISO 27001 pour rassurer contractuellement ses clients, tout en utilisant le NIST CSF en interne comme grille de lecture pédagogique pour communiquer sur sa maturité auprès de la direction.

6. Maturité et amélioration continue

La gouvernance SSI n'est jamais un état figé, atteint une fois pour toutes : c'est une démarche qui progresse par cycles successifs, souvent modélisés sous la forme du cycle **PDCA** (*Plan, Do, Check, Act* — Planifier, Déployer, Vérifier, Agir), largement popularisé par les normes de management (dont l'ISO 27001). Ce cycle formalise l'idée qu'une organisation doit périodiquement revisiter ses choix de sécurité à la lumière des résultats obtenus et de l'évolution de son contexte (nouvelles menaces, nouveaux projets, évolutions réglementaires).

On distingue généralement plusieurs niveaux de maturité, du plus faible au plus élevé :

- Une organisation **immature** réagit aux incidents au coup par coup : les mesures de sécurité sont mises en place de façon ponctuelle, en réponse à un événement précis (un incident subi, un audit ponctuel), sans vision d'ensemble ni continuité dans le temps.
- Une organisation en cours de **structuration** commence à documenter ses processus, à désigner des responsables clairs et à formaliser une politique de sécurité, mais l'application reste inégale selon les équipes ou les projets.
- Une organisation **mature** anticipe les risques par une gestion structurée et continue : elle dispose d'indicateurs fiables, revoit régulièrement ses priorités sur la base de retours d'expérience documentés, et intègre la sécurité dès la conception de ses projets plutôt que de la traiter comme une contrainte ajoutée a posteriori.

Des modèles de maturité formalisés (par exemple issus de la famille des modèles CMM — *Capability Maturity Model* — adaptés à la sécurité) permettent de positionner objectivement une organisation sur une échelle et de définir une trajectoire de progression réaliste, étape par étape, plutôt que de viser un niveau d'excellence hors d'atteinte à court terme. Cette progression graduelle est d'ailleurs un principe pédagogique important : il vaut mieux consolider durablement un niveau de maturité correct que d'afficher des ambitions élevées sans les moyens de les tenir dans la durée.

À retenir

- La gouvernance SSI relève de la direction, pas uniquement des équipes techniques : elle arbitre l'appétence au risque et les moyens alloués, et se distingue de la sécurité opérationnelle qui exécute ces orientations.
- Les conséquences d'un incident majeur (juridiques, financières, réputationnelles) dépassent le périmètre informatique, ce qui justifie l'implication de la direction générale dans les décisions de sécurité.
- Un RSSI efficace a besoin d'un positionnement organisationnel qui préserve son indépendance vis-à-vis de la DSI, afin de pouvoir challenger les arbitrages techniques sans conflit d'intérêts.
- La gouvernance s'appuie sur cinq composantes articulées en cycle continu : politique de sécurité, organisation, gestion des risques, conformité, pilotage et amélioration.
- Des référentiels internationaux (ISO/IEC 27001, COBIT, NIST CSF) structurent la pratique de la gouvernance SSI et sont souvent utilisés de façon complémentaire.
- La maturité d'une gouvernance SSI se construit progressivement, par cycles PDCA successifs, et non par un effort ponctuel isolé.

Chapitre 2 — Méthodologies d'analyse de risques

Gouvernance et gestion des risques SI

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Vocabulaire de base de la gestion des risques

Avant d'aborder les méthodologies elles-mêmes, il est indispensable de maîtriser un vocabulaire précis, car les termes de la gestion des risques sont souvent employés de façon approximative dans le langage courant, au risque de brouiller l'analyse :

Terme	Définition
Actif (asset)	tout élément ayant de la valeur pour l'organisation : une donnée, un système, un processus métier, un savoir-faire, ou même une image de marque. C'est ce qu'il s'agit, in fine, de protéger
Menace	événement potentiel pouvant porter atteinte à un actif : attaque délibérée, erreur humaine, panne technique, catastrophe naturelle. Une menace existe indépendamment de l'organisation qui y est exposée
Vulnérabilité	faiblesse propre à l'actif ou à son environnement, exploitable par une menace pour produire un dommage. Sans vulnérabilité correspondante, une menace reste sans effet
Risque	combinaison de la probabilité qu'une menace donnée exploite une vulnérabilité donnée, et de l'impact qui en résulterait pour l'organisation. Le risque n'existe donc que par la rencontre d'une menace et d'une vulnérabilité sur un actif de valeur
Mesure de sécurité (contrôle)	action, technique ou organisationnelle, visant à réduire la probabilité et/ou l'impact d'un risque identifié
Risque résiduel	risque subsistant après application des mesures de sécurité retenues ; il n'est jamais nul en pratique, et c'est ce risque résiduel qui doit être formellement accepté par la gouvernance

Ces définitions s'articulent entre elles de façon logique : un actif de valeur, exposé à une menace, présentant une vulnérabilité que cette menace peut exploiter, constitue un risque ; une fois ce risque traité par des mesures de sécurité, il subsiste un risque résiduel, qu'il faut alors gérer consciemment plutôt que de l'ignorer.

La formule la plus couramment citée pour qualifier un risque est : **Risque = Probabilité × Impact**. Il est toutefois important de comprendre que cette formule est avant tout un outil pédagogique de synthèse, rarement appliquée comme un calcul numérique littéral en pratique. Les méthodes professionnelles préfèrent en général des échelles qualitatives à 3, 4 ou 5 niveaux (par exemple « rare / possible / probable / quasi certain » pour la probabilité), plus faciles à faire converger entre plusieurs experts métier que des probabilités chiffrées, dont la précision serait de toute façon illusoire dans la plupart des contextes.

2. EBIOS Risk Manager (méthode ANSSI)

EBIOS Risk Manager (EBIOS RM) est la méthode d'analyse de risques cybersécurité publiée par l'ANSSI (Agence nationale de la sécurité des systèmes d'information, France), largement diffusée dans les administrations et les grandes organisations francophones. Elle structure l'analyse en cinq ateliers successifs, chacun s'appuyant sur les livrables du précédent :

1. **Cadrage et socle de sécurité** : cet atelier définit le périmètre de l'étude, identifie les missions et les valeurs métier de l'organisation (ce qui compte vraiment, du point de vue métier, et non uniquement technique), ainsi que les événements redoutés — c'est-à-dire les situations que l'organisation cherche absolument à éviter. Il établit également un socle de mesures de sécurité déjà en place, servant de base de référence pour la suite de l'analyse.
2. **Sources de risque** : cet atelier identifie qui pourrait vouloir porter atteinte à l'organisation — un attaquant opportuniste sans cible précise, un concurrent cherchant un avantage économique, un État cherchant à collecter du renseignement, ou un initié malveillant disposant déjà d'un accès légitime — ainsi que les objectifs visés par chacune de ces sources de risque.
3. **Scénarios stratégiques** : cet atelier construit des chemins d'attaque à haut niveau, en s'appuyant sur une cartographie de l'écosystème de l'organisation (fournisseurs, prestataires, partenaires), car ces tiers constituent fréquemment des vecteurs d'attaque indirects, souvent moins protégés que l'organisation elle-même.
4. **Scénarios opérationnels** : cet atelier détaille le déroulé technique probable d'une attaque retenue au stade stratégique, en précisant un mode opératoire réaliste (techniques, tactiques et procédures) permettant d'évaluer plus finement la vraisemblance du scénario.
5. **Traitement du risque** : cet atelier de synthèse rassemble l'ensemble des risques analysés, formalise les décisions de traitement retenues (éviter, réduire, transférer, accepter — cf. chapitre 3), et débouche sur un plan d'action concret assorti d'un dispositif de suivi.

La spécificité d'EBIOS RM, par rapport à des approches plus classiques, est de raisonner « **par la menace** » : la méthode part des scénarios d'attaque plausibles et de leurs auteurs potentiels pour remonter vers les vulnérabilités exploitées, en complément d'une approche plus traditionnelle « **par les actifs** », qui part de l'inventaire des biens à protéger. Cette approche par la menace permet de mieux prioriser l'analyse sur les scénarios réellement crédibles pour l'organisation considérée, plutôt que de traiter uniformément un inventaire exhaustif et souvent trop large d'actifs.

3. ISO/IEC 27005

ISO/IEC 27005 est la norme internationale de référence pour la gestion des risques liés à la sécurité de l'information. Contrairement à ISO/IEC 27001, qui n'est pas elle-même certifiable de façon indépendante, elle fournit des lignes directrices détaillées permettant de satisfaire les exigences de gestion des risques imposées par la clause 6 de l'ISO 27001, dans une logique de certification du SMSI (Système de Management de la Sécurité de l'Information).

Le processus décrit par la norme s'articule en six étapes :

1. **Établissement du contexte** : définition des critères de risque (échelles retenues, seuils d'acceptabilité) et délimitation précise du périmètre de l'étude.
2. **Appréciation du risque** : cette étape regroupe elle-même trois sous-activités — l'identification des risques (quels actifs, quelles menaces, quelles vulnérabilités), leur analyse (estimation de la probabilité et de l'impact), et leur évaluation (comparaison aux critères d'acceptabilité définis au préalable, pour déterminer les risques nécessitant un traitement prioritaire).
3. **Traitement du risque** : sélection et mise en œuvre des mesures de sécurité appropriées, selon les stratégies détaillées au chapitre 3 (éviter, réduire, transférer, accepter).
4. **Acceptation du risque** : validation formelle, par le niveau de gouvernance approprié, du risque résiduel subsistant après traitement.
5. **Communication et concertation** : échanges continus, tout au long du processus, entre les parties prenantes internes (direction, métiers, IT) et parfois externes (régulateurs, partenaires), afin que les décisions de risque restent partagées et comprises.
6. **Surveillance et revue** : suivi dans la durée de l'évolution du contexte (nouvelles menaces, nouveaux actifs, changements organisationnels) et de l'efficacité des mesures mises en œuvre, afin de réévaluer périodiquement les risques.

Il est important de noter que la communication/concertation et la surveillance/revue ne sont pas des étapes isolées en fin de processus : elles se déroulent en continu, en parallèle des autres étapes, ce qui fait d'ISO 27005 un processus itératif plutôt qu'une séquence strictement linéaire.

4. NIST Risk Management Framework (RMF)

Le **NIST Risk Management Framework** (RMF), publié par l'institut américain de normalisation NIST, est un cadre structuré en sept étapes : *Prepare* (préparer), *Categorize* (catégoriser), *Select* (sélectionner), *Implement* (mettre en œuvre), *Assess* (évaluer), *Authorize* (autoriser) et *Monitor* (surveiller). Il est largement utilisé dans le secteur public américain ainsi que par les organisations et sous-traitants amenés à travailler avec des agences fédérales.

Sa caractéristique la plus distinctive est l'articulation forte entre, d'une part, la **catégorisation des systèmes** en fonction de leur impact potentiel (faible, modéré, élevé, selon l'impact sur la confidentialité, l'intégrité et la disponibilité), et d'autre part, la **sélection de mesures de sécurité** issues d'un catalogue détaillé et normalisé, le NIST SP 800-53. Cette approche « par catalogue » diffère sensiblement de la logique par scénarios d'EBIOS RM : plutôt que de construire des chemins d'attaque sur mesure, l'organisation choisit, dans une liste de contrôles pré-établie et éprouvée, ceux qui correspondent au niveau de criticité du système considéré, ce qui favorise la cohérence et la comparabilité entre systèmes au sein d'une même organisation ou d'un même secteur.

5. Comparaison synthétique

Le tableau ci-dessous synthétise les principales différences entre ces trois méthodes, pour aider à choisir le référentiel le plus adapté à un contexte donné :

Critère	EBIOS RM	ISO 27005	NIST RMF
Origine	France (ANSSI)	International (ISO)	États-Unis (NIST)
Approche dominante	par la menace (scénarios d'attaque)	par les actifs et le contexte	par la catégorisation et un catalogue de contrôles
Structure	5 ateliers séquentiels	6 étapes itératives	7 étapes séquentielles
Usage typique	administrations, opérateurs d'importance vitale, grandes entreprises francophones	démarche de certification ISO 27001	secteur public américain, sous-traitants fédéraux
Niveau de prescription	méthodologique, avec une forte dimension narrative (scénarios)	lignes directrices générales, à adapter	très prescriptif via le catalogue SP 800-53

Ces méthodes ne sont pas mutuellement exclusives : elles répondent à des logiques différentes mais compatibles, et rien n'empêche une organisation de les combiner selon ses besoins. Par exemple, une organisation peut s'appuyer sur ISO 27005 comme cadre général pour son SMSI certifié, tout en mobilisant les ateliers EBIOS RM pour affiner l'analyse des scénarios d'attaque jugés les plus critiques, ou encore s'inspirer du catalogue NIST SP 800-53 pour objectiver le choix de mesures de sécurité concrètes une fois les risques prioritaires identifiés.

6. Échelles d'évaluation

Quelle que soit la méthode retenue, l'analyse de risque nécessite de traduire les notions de probabilité et d'impact en échelles concrètes, partagées et comprises par l'ensemble des parties prenantes impliquées dans l'exercice. Un exemple d'échelle qualitative simple à 4 niveaux, utilisable en travaux pratiques, est présenté ci-dessous :

Niveau	Probabilité	Impact
1	Rare	Négligeable
2	Possible	Modéré
3	Probable	Majeur
4	Quasi certain	Critique (met en péril la continuité)

Ces échelles doivent être définies et documentées **avant** de commencer l'analyse, et idéalement validées collectivement, car leur interprétation peut varier fortement d'un évaluateur à l'autre en l'absence de définitions précises (par exemple, préciser ce que recouvre concrètement « impact majeur » pour l'organisation considérée : perte financière au-delà d'un certain seuil, interruption de service au-delà d'une certaine durée, etc.).

La combinaison de la probabilité et de l'impact permet de positionner chaque risque identifié sur une **matrice de criticité** (parfois appelée matrice de risque), généralement représentée sous la forme d'un tableau à double entrée où chaque case correspond à un niveau de priorité de traitement (par exemple : vert pour un risque faible acceptable en l'état, jaune pour un risque à surveiller, orange pour un risque nécessitant un traitement à moyen terme, rouge pour un risque nécessitant un traitement immédiat). Cet outil visuel simple, mais puissant, constitue le support central de priorisation des risques et sera repris et manipulé concrètement lors du deuxième travail pratique du cours.

À retenir

- Un risque naît de la rencontre entre une menace, une vulnérabilité et un actif de valeur ; il se qualifie par la combinaison de la probabilité d'occurrence et de l'impact potentiel, jamais l'un sans l'autre.
- EBIOS RM structure l'analyse « par la menace » en cinq ateliers successifs (cadrage, sources de risque, scénarios stratégiques, scénarios opérationnels, traitement du risque).
- ISO 27005 structure l'analyse « par le contexte et les actifs » en six étapes itératives, et sert de référence pour satisfaire les exigences de gestion des risques de l'ISO 27001.
- Le NIST RMF articule catégorisation des systèmes et sélection de contrôles dans un catalogue normalisé (NIST SP 800-53), pour une approche plus prescriptive.
- Le choix de la méthode dépend souvent du contexte réglementaire et sectoriel de l'organisation, et ces méthodes peuvent être combinées plutôt qu'opposées.
- La matrice de criticité, construite à partir d'échelles de probabilité et d'impact définies au préalable, est l'outil central de priorisation des risques identifiés.

Chapitre 3 — Traitement du risque, PSSI et continuité d'activité

Gouvernance et gestion des risques SI

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Les quatre stratégies de traitement du risque

Une fois un risque identifié et évalué selon les méthodes présentées au chapitre 2, l'organisation doit décider comment le traiter. La littérature de gestion des risques distingue classiquement quatre stratégies, qui ne sont pas mutuellement exclusives et peuvent d'ailleurs se combiner pour un même risque (par exemple réduire un risque tout en transférant une partie résiduelle de son impact) :

Stratégie	Principe	Exemple
Éviter	supprimer purement et simplement l'activité ou l'actif qui génère le risque, lorsque le risque encouru est jugé disproportionné par rapport au bénéfice attendu	ne pas exposer un service inutile sur Internet, renoncer à un projet dont le profil de risque est jugé inacceptable
Réduire (atténuer)	mettre en œuvre des mesures de sécurité, techniques ou organisationnelles, pour diminuer la probabilité d'occurrence et/ou l'impact du risque	déployer un pare-feu, chiffrer les données sensibles, former les utilisateurs, mettre en place une authentification à plusieurs facteurs
Transférer (partager)	déplacer une partie de la charge de l'impact vers un tiers, sans pour autant faire disparaître le risque lui-même	souscrire une cyber-assurance, externaliser une activité à un prestataire avec des obligations contractuelles précises (clauses de sécurité, garanties de service)
Accepter	assumer consciemment le risque en l'état, en général lorsque le coût du traitement dépasse l'impact potentiel estimé, ou lorsque le risque résiduel après traitement est jugé suffisamment faible	accepter un risque résiduel faible après mise en œuvre des mesures de sécurité principales jugées prioritaires

Un point essentiel, souvent négligé par les organisations peu matures : le **transfert** ne fait jamais disparaître totalement le risque. Une cyber-assurance peut compenser une perte financière, mais elle ne restaure ni la confiance des clients, ni la disponibilité immédiate d'un service interrompu, ni la conformité réglementaire en cas de manquement constaté. De même, externaliser une activité à un prestataire déplace la responsabilité opérationnelle mais laisse en général subsister, aux yeux du régulateur ou des clients, une part de responsabilité pour l'organisation donneuse d'ordre.

Le choix entre ces quatre stratégies résulte toujours d'un **arbitrage coût/bénéfice**, qui doit être validé par le niveau de gouvernance approprié au regard de l'ampleur du risque considéré : une décision d'accepter un risque mineur peut relever d'un responsable opérationnel, tandis qu'une décision d'accepter un risque majeur, susceptible de menacer la continuité de l'organisation, doit impérativement remonter jusqu'à la direction générale, conformément aux principes de gouvernance présentés au chapitre 1.

La **PSSI** (Politique de Sécurité des Systèmes d'Information) est le document de référence qui formalise les orientations stratégiques et les règles de sécurité applicables à l'ensemble de l'organisation. Elle traduit, en engagements écrits et opposables, les décisions prises au niveau de la gouvernance. Une PSSI complète se décline généralement en plusieurs niveaux, du plus stratégique au plus opérationnel :

1. **Politique générale** : document court (quelques pages), stable dans le temps, qui fixe les grands principes, l'engagement formel de la direction et le périmètre d'application de la politique de sécurité.
2. **Politiques thématiques** : documents plus détaillés, couvrant chacun un domaine précis — contrôle d'accès, gestion des mots de passe, usage des équipements mobiles, télétravail, gestion des relations avec les tiers et prestataires, entre autres.
3. **Procédures opérationnelles** : instructions détaillées, destinées aux équipes opérationnelles, précisant très concrètement comment appliquer les règles définies aux niveaux précédents (par exemple, la procédure exacte de gestion d'un incident de sécurité, ou la procédure de réalisation des sauvegardes).

Cette structuration en niveaux permet de concilier deux besoins a priori contradictoires : la stabilité de la politique générale, qui ne doit pas être révisée trop fréquemment pour conserver son autorité, et l'agilité des procédures opérationnelles, qui doivent pouvoir évoluer rapidement au gré des évolutions techniques et organisationnelles, sans nécessiter à chaque fois une validation lourde par la direction.

Structure type d'une politique générale

Une politique générale de sécurité comprend typiquement les rubriques suivantes :

- **Objet et périmètre** : ce que couvre la politique, et ce qu'elle ne couvre pas.
- **Engagement de la direction** : signature ou validation formelle par la direction générale, condition essentielle de sa légitimité.
- **Organisation et responsabilités** : rappel des rôles définis au chapitre 1 (direction, RSSI, DSI, propriétaires métier, correspondants sécurité).
- **Principes directeurs** : principes structurants tels que le moindre privilège (n'accorder que les droits strictement nécessaires), la défense en profondeur (superposer plusieurs couches de protection indépendantes) et la séparation des tâches (éviter qu'une même personne cumule des pouvoirs qui, combinés, créeraient un risque de fraude ou d'erreur non détectée).
- **Gestion des risques et conformité** : rappel du processus de gestion des risques retenu (cf. chapitre 2) et des obligations de conformité applicables.
- **Sanctions en cas de non-respect** : conséquences prévues en cas de manquement, qu'il s'agisse d'un manquement individuel ou organisationnel.
- **Modalités de révision** : fréquence et déclencheurs de mise à jour de la politique.

Une PSSI efficace est **connue, appliquée et révisée régulièrement**. Une politique rédigée avec soin, mais jamais diffusée auprès des collaborateurs concernés, jamais expliquée, ni jamais actualisée pour tenir compte des évolutions de l'organisation, est un signe classique

Notions clés

Deux indicateurs structurent la conception de tout PCA/PRA :

Indicateur	Définition
RTO (Recovery Time Objective)	durée maximale d'interruption acceptable avant reprise du service, mesurée depuis le moment de l'incident
RPO (Recovery Point Objective)	perte de données maximale acceptable, exprimée en temps écoulé depuis la dernière sauvegarde exploitable (ex. un RPO de 4 heures signifie que l'organisation accepte de perdre, au maximum, les 4 dernières heures de données produites)

Ces deux indicateurs, qui doivent être définis processus par processus (tous les processus métier ne partagent pas la même criticité), déterminent directement l'architecture de résilience à mettre en œuvre. Un RTO très court impose, par exemple, un site de secours actif en permanence (bascule quasi immédiate), tandis qu'un RTO plus long peut se satisfaire d'un site de secours passif, activé seulement en cas de besoin, à moindre coût. De même, un RPO très court impose une réplication des données en temps réel ou quasi réel, tandis qu'un RPO plus tolérant peut se contenter de sauvegardes périodiques classiques.

Exigence	RTO/RPO court	RTO/RPO long
Architecture typique	site de secours actif, réplication temps réel	site de secours passif, sauvegardes périodiques
Coût	élevé	plus modéré
Processus concernés	processus critiques (ex. paiement, production)	processus support, moins sensibles au temps

Étapes d'élaboration d'un PCA

L'élaboration d'un PCA suit un enchaînement logique en cinq étapes :

1. **Analyse d'impact sur l'activité** (BIA — *Business Impact Analysis*) : cette étape, réalisée en amont avec les propriétaires métier, identifie les processus critiques de l'organisation et détermine, pour chacun, un RTO et un RPO cible, en fonction de la gravité des conséquences d'une interruption.
2. **Définition des stratégies de continuité** : choix des solutions permettant de tenir les objectifs fixés (site de secours, télétravail de crise, procédures dégradées permettant de maintenir un service minimal).
3. **Rédaction des plans opérationnels** : formalisation précise de qui fait quoi, avec quelles ressources, dans quel ordre, en cas de déclenchement effectif du plan.
4. **Tests réguliers** : organisation d'exercices de crise (simulations impliquant les équipes concernées) et de tests techniques de bascule

4. Gestion de crise cyber

La gestion de crise cyber est une démarche distincte du PCA/PRA, mais qui lui est étroitement complémentaire. Alors que le PCA/PRA prépare la continuité et la reprise des activités et des systèmes, la gestion de crise organise la **prise de décision** pendant l'incident lui-même, dans un contexte souvent marqué par l'incertitude, l'urgence et une forte pression médiatique ou réglementaire potentielle.

Concrètement, une organisation mature met en place une **cellule de crise dédiée**, réunissant généralement le RSSI, la DSI, la direction de la communication, la direction juridique et la direction générale, capable d'être activée rapidement en cas d'incident majeur (par exemple une attaque par rançongiciel bloquant une partie significative du système d'information). Cette cellule s'appuie sur des procédures de décision pré-établies, préparées à froid avant toute crise, afin d'éviter d'avoir à improviser des choix critiques sous forte pression :

- **Isoler** : contenir la propagation de l'incident (déconnecter les systèmes compromis, couper certains accès réseau).
- **Communiquer** : gérer la communication interne (personnel) et externe (clients, partenaires, médias le cas échéant) de façon cohérente et maîtrisée.
- **Notifier** : le cas échéant, informer les autorités compétentes conformément aux obligations réglementaires applicables (protection des données, réglementations sectorielles de cybersécurité).

La préparation en amont de cette cellule de crise — par des exercices réguliers, au même titre que les tests du PCA — conditionne largement la capacité réelle de l'organisation à réagir efficacement le jour où un incident survient effectivement.

À retenir

- Quatre stratégies de traitement du risque : éviter, réduire, transférer, accepter — le choix relève d'un arbitrage coût/bénéfice validé par le niveau de gouvernance approprié à l'ampleur du risque.
- Le transfert du risque (assurance, externalisation) ne fait jamais disparaître totalement le risque ni la responsabilité de l'organisation.
- La PSSI se décline en plusieurs niveaux, de la politique générale aux procédures opérationnelles, et doit être vivante : connue, diffusée, appliquée et révisée régulièrement.
- RTO et RPO traduisent en exigences techniques concrètes la criticité de chaque processus métier, et dimensionnent directement l'architecture de résilience (site de secours, fréquence de réplication).
- Un PCA/PRA non testé reste théorique : les exercices réguliers sont aussi essentiels que la rédaction du plan lui-même.
- La gestion de crise cyber organise la prise de décision pendant l'incident (isoler, communiquer, notifier), en complément — et non en substitution — du PCA/PRA.

Chapitre 4 — Pilotage, indicateurs et conformité réglementaire

Gouvernance et gestion des risques SI

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Pourquoi piloter par les indicateurs

Une gouvernance SSI mature ne se limite pas à produire des documents — une PSSI rédigée, des analyses de risque menées une fois, un plan de continuité archivé : elle démontre, dans la durée, une **amélioration mesurable et continue**. C'est précisément le rôle des indicateurs que de rendre visible, objectivement, ce qui autrement resterait une impression subjective (« nous sommes plutôt bien protégés », « la situation s'améliore »).

Les indicateurs remplissent trois fonctions essentielles dans le dispositif de gouvernance :

- **Communiquer objectivement avec la direction** : des indicateurs chiffrés et suivis dans le temps permettent au RSSI de rendre compte de façon crédible et argumentée, plutôt que par des affirmations générales difficiles à vérifier.
- **Détecter une dérive avant qu'elle ne devienne un incident** : un indicateur qui se dégrade progressivement (par exemple un allongement du délai d'application des correctifs de sécurité) est souvent un signal d'alerte précoce, permettant d'agir avant que la dégradation ne se traduise par un incident effectif.
- **Justifier les investissements** : face à des arbitrages budgétaires concurrents (cf. chapitre 1), des indicateurs solides permettent d'argumenter objectivement en faveur d'un investissement de sécurité, en montrant par exemple qu'un indicateur reste durablement dégradé faute de moyens suffisants.

Sans dispositif de pilotage, la gouvernance SSI risque de rester une démarche essentiellement déclarative, difficile à distinguer d'une simple accumulation de bonnes intentions non vérifiées.

2. Caractéristiques d'un bon indicateur

Tous les indicateurs ne se valent pas. Un indicateur mal conçu peut même s'avérer contre-productif, en mobilisant du temps de collecte sans apporter d'information exploitable. La pratique de gestion recommande généralement de vérifier qu'un indicateur respecte les critères **SMART** :

- **Spécifique** : porte sur un aspect précis et clairement délimité, sans ambiguïté d'interprétation.
- **Mesurable** : peut être quantifié de façon fiable et reproductible, à partir de données réellement disponibles.
- **Atteignable** : la cible fixée doit être réaliste au regard des moyens dont dispose l'organisation.
- **Réaliste** (ou *pertinent*) : doit correspondre à un enjeu réellement significatif pour l'organisation, et non à une donnée facile à collecter mais peu utile.
- **Temporellement défini** : associé à une fréquence de mesure et, si nécessaire, à une échéance cible.

Au-delà de ces critères classiques, un indicateur utile doit surtout être **actionnable** : c'est-à-dire qu'il doit exister une décision concrète que l'organisation pourrait prendre en réaction à son évolution. Un indicateur qui ne débouche sur aucune décision possible — parce qu'il n'est rattaché à aucun responsable, à aucun processus de décision, ou parce qu'il ne dit rien sur ce qu'il faudrait faire s'il se dégradait — n'a en réalité aucun intérêt opérationnel, même s'il paraît sophistiqué sur le papier. Cette exigence d'actionnabilité doit systématiquement primer sur la tentation de multiplier les indicateurs pour donner une impression de rigueur.

3. Exemples d'indicateurs SSI

Le tableau suivant présente des exemples d'indicateurs couramment utilisés en gouvernance SSI, répartis par catégorie :

Catégorie	Exemple d'indicateur
Vulnérabilités	délai moyen d'application des correctifs critiques (<i>patch management</i>), nombre de vulnérabilités critiques ouvertes depuis plus d'un délai cible donné
Incidents	nombre d'incidents de sécurité déclarés par mois, temps moyen de détection (MTTD — <i>Mean Time To Detect</i>), temps moyen de résolution (MTTR — <i>Mean Time To Resolve</i>)
Sensibilisation	taux de clics sur des campagnes de simulation de phishing, taux de complétion des formations obligatoires de sensibilisation
Conformité	pourcentage d'exigences ISO 27001 couvertes par des mesures effectivement mises en œuvre, nombre de non-conformités ouvertes lors du dernier audit
Continuité	résultat des derniers tests de PCA/PRA (RTO/RPO atteints ou non lors de l'exercice)
Accès	nombre de comptes à privilèges actifs, délai moyen de révocation des accès après le départ d'un collaborateur

Chaque catégorie répond à une préoccupation de gouvernance distincte : les indicateurs de vulnérabilités et d'incidents mesurent l'exposition technique réelle, les indicateurs de sensibilisation mesurent le facteur humain (souvent identifié comme un vecteur d'attaque important dans les scénarios EBIOS RM — cf. chapitre 2), les indicateurs de conformité mesurent l'écart par rapport aux référentiels normatifs, les indicateurs de continuité mesurent la préparation aux crises (cf. chapitre 3), et les indicateurs d'accès mesurent l'application effective du principe de moindre privilège.

Il est préférable de retenir un nombre restreint d'indicateurs réellement suivis et exploités, plutôt qu'une liste exhaustive mais rarement mise à jour : la valeur d'un tableau de bord tient davantage à la régularité et à la fiabilité de son suivi qu'à l'exhaustivité de son contenu.

4. Tableau de bord SSI

Un tableau de bord SSI synthétise ces indicateurs pour des publics différents, dont les besoins d'information ne sont pas les mêmes :

- **Vision direction** : un nombre volontairement restreint d'indicateurs agrégés, présentés avec leur tendance (amélioration ou dégradation par rapport à la période précédente) et un niveau de risque global synthétique. L'objectif est de permettre une lecture rapide, en quelques minutes, sans nécessiter d'expertise technique.
- **Vision RSSI / opérationnelle** : des indicateurs beaucoup plus détaillés, ventilés par domaine (vulnérabilités, incidents, conformité, etc.), permettant d'identifier précisément les points d'action prioritaires et de piloter le travail des équipes au quotidien.

Cette différenciation par public est essentielle : présenter à la direction générale le même niveau de détail qu'aux équipes opérationnelles risquerait de noyer l'information réellement stratégique dans un volume de données difficile à interpréter rapidement, tandis qu'un tableau de bord trop agrégé serait, à l'inverse, inutilisable pour piloter le travail quotidien des équipes techniques.

La **fréquence de mise à jour** (mensuelle pour un suivi opérationnel rapproché, trimestrielle pour une vision plus stratégique) et le **format de restitution** (comité de pilotage sécurité, revue de direction périodique) ne doivent pas être laissés à l'improvisation : ils doivent être définis explicitement dans le dispositif de gouvernance lui-même, au même titre que les rôles et responsabilités présentés au chapitre 1.

5. Conformité réglementaire : panorama non exhaustif

La conformité réglementaire constitue un pan important — mais non exclusif — de la gouvernance SSI. Le tableau suivant dresse un panorama, volontairement non exhaustif, des grandes catégories d'obligations auxquelles une organisation peut être soumise :

Cadre réglementaire	Portée	Point clé
RGPD (et lois nationales équivalentes de protection des données)	données à caractère personnel	notification des violations de données aux autorités compétentes, analyse d'impact relative à la protection des données (AIPD) exigée pour les traitements à risque élevé
Réglementations sectorielles (banque, assurance, santé, télécommunications)	secteurs régulés	exigences souvent renforcées par rapport au droit commun, par exemple en matière de résilience opérationnelle dans le secteur financier
Réglementations nationales de cybersécurité (souvent inspirées de directives régionales)	opérateurs d'importance vitale ou d'entités jugées essentielles	obligations de déclaration d'incident dans des délais contraints, exigences techniques minimales imposées
Exigences contractuelles	relations clients / fournisseurs	souvent alignées sur la certification ISO 27001 ou formalisées via des questionnaires de sécurité spécifiques imposés par les clients

Un point conceptuel important à retenir : la **conformité n'est pas un objectif en soi**, mais un sous-ensemble de la gestion des risques au sens large. Une organisation peut être formellement conforme à un référentiel réglementaire tout en restant, dans les faits, insuffisamment sécurisée — la conformité fixe souvent un plancher d'exigences minimales, pas un plafond de sécurité optimale. Inversement, une organisation peut être réellement bien sécurisée sur le plan opérationnel tout en devant néanmoins documenter et démontrer formellement sa conformité, ne serait-ce que pour répondre à ses obligations légales et contractuelles vis-à-vis de ses clients, partenaires ou régulateurs. La conformité et la sécurité effective doivent donc être pilotées conjointement, sans que l'une se substitue à l'autre.

6. Revue de direction et amélioration continue

La norme **ISO/IEC 27001** impose une **revue de direction** périodique du SMSI (Système de Management de la Sécurité de l'Information), qui constitue le point de bouclage formel du cycle PDCA (*Plan, Do, Check, Act*) introduit au chapitre 1. Cette revue doit examiner un ensemble d'éléments précis, afin que la direction dispose d'une vision complète pour prendre des décisions éclairées :

- Les résultats des **audits internes et externes** menés depuis la revue précédente.
- L'**état d'avancement du traitement des risques** identifiés (cf. chapitre 2 et chapitre 3), y compris les risques dont le traitement a pris du retard.
- Les **indicateurs de performance** du dispositif de sécurité, tels que présentés dans ce chapitre.
- Les **retours des parties intéressées** (clients, partenaires, régulateurs, personnel), qui peuvent révéler des attentes ou des préoccupations non captées par les seuls indicateurs internes.

Cette revue de direction ne doit pas rester un exercice formel sans conséquence : elle doit systématiquement déboucher sur des **décisions concrètes** — allocation ou réallocation de ressources, ajustement des priorités de traitement des risques, révision de la politique de sécurité si nécessaire. C'est cette exigence de décision effective qui referme réellement la boucle du cycle d'amélioration continue, et qui distingue une gouvernance SSI vivante d'une gouvernance purement documentaire : les constats et les indicateurs présentés lors de la revue n'ont de valeur que s'ils nourrissent, en retour, les orientations et les priorités du cycle suivant.

À retenir

- Un indicateur SSI doit être actionnable, pas seulement descriptif : il doit exister une décision concrète que l'organisation pourrait prendre en fonction de son évolution.
- Les indicateurs se répartissent en plusieurs catégories complémentaires (vulnérabilités, incidents, sensibilisation, conformité, continuité, accès), chacune éclairant une dimension différente de la sécurité.
- Le tableau de bord se décline selon le public visé (direction vs opérationnel), avec des niveaux de détail et des fréquences de mise à jour adaptés à chacun.
- La conformité réglementaire est une composante de la gestion des risques, pas un objectif indépendant ; être conforme ne garantit pas d'être sécurisé, et inversement.
- La revue de direction ISO 27001 referme le cycle PDCA en examinant audits, risques, indicateurs et retours des parties intéressées, et doit déboucher sur des décisions concrètes.